

# IMPLEMENTING A SECURE EMAIL COMMUNICATION SYSTEM

Email Security Architecture Design Document

*Deliverable 1 of 6*

Submitted by  
**Atharva Devendra Kshirsagar**

## Table of Contents

1. Executive Summary
2. Current Infrastructure Assessment
3. Proposed Architecture
4. Technology Selection
5. Integration Plan
6. Conclusion

## 1. Executive Summary

This document presents my proposed architecture for securing the email communication infrastructure of a global consulting firm. While working through this project I noticed that most traditional email setups lack three core security guarantees - confidentiality, integrity, and authentication. The approach taken in this design addresses each of these through specific technology choices that can be deployed without commercial licensing costs.

The recommended architecture follows a defense-in-depth model, layering encryption, authentication, gateway filtering, and policy controls. Practical implementation was carried out on my Kali Linux VM using open-source tools including GPG, BIND9 (named), SpamAssassin, ClamAV, and a custom Python-based DLP engine. Screenshots and configurations from this hands-on work are referenced throughout this document and in the supporting deliverables.

My goal was to keep the solution realistic for a mid-to-large consulting firm: strong enough to protect sensitive client data, but practical enough that the IT team can operate it without specialized vendor support.

## 2. Current Infrastructure Assessment

### 2.1 Assumed Current State

Before designing the new system I worked through what a typical insecure email environment looks like in a consulting firm context. Based on this assessment, the following baseline state was assumed:

- Standard SMTP relay without enforced TLS
- No SPF, DKIM, or DMARC records configured on the company domain
- Mail server reachable from the public internet without a dedicated gateway
- Single-factor password authentication for mailbox access
- No content inspection on outbound mail for sensitive data
- Antivirus runs only on endpoints, not on inbound mail
- No structured employee training programme on phishing or email handling

### 2.2 Identified Gaps

From the assessment, six concrete gaps were identified that this architecture aims to close:

- Lack of end-to-end encryption - emails travel as plain text, exposing client information during transit
- No sender authentication - the domain can be trivially spoofed in phishing campaigns
- Absent spam, phishing, and malware filter at the perimeter
- No data loss prevention - sensitive numbers like PAN, Aadhaar, and card data can leave the network undetected
- Weak authentication - a single compromised password is enough to access years of stored email
- No defined incident response process for email compromise or phishing reports

### 3. Proposed Architecture

The proposed architecture is built around the defense-in-depth principle, where each layer addresses a distinct threat and failure in any single layer does not collapse the whole system.

#### 3.1 Architecture Diagram

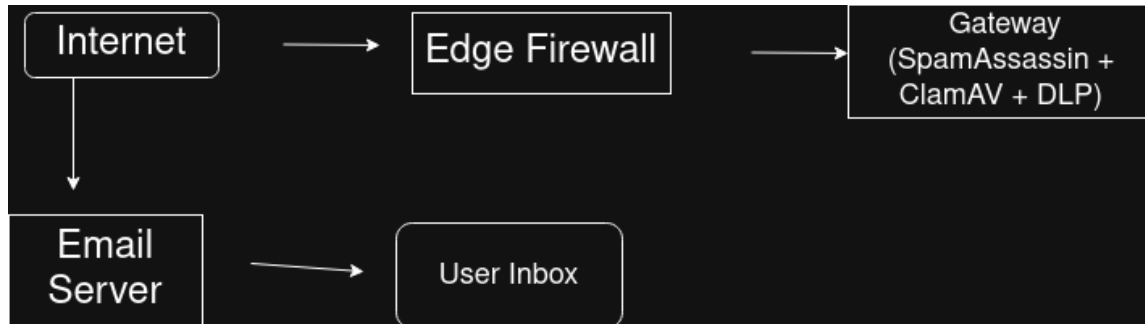


Figure 1: Proposed secure email communication architecture

#### 3.2 Component Description

Each component in the architecture plays a specific role:

- Edge Firewall - first network boundary, drops obviously malicious traffic before it reaches mail systems
- Secure Email Gateway - runs SpamAssassin for spam scoring and ClamAV for malware scanning on inbound mail
- DLP Engine - custom Python module that inspects outbound mail bodies for sensitive patterns and blocks accordingly
- Mail Server - core SMTP/IMAP service, receives mail only after it has passed gateway checks
- Encryption Layer - PGP for technical staff and S/MIME for executive users handling external clients
- DNS Authentication - SPF, DKIM, and DMARC records configured on a BIND9 authoritative server to prove sender identity
- User Endpoints - Thunderbird configured with OpenPGP, plus mandatory multi-factor authentication

## 4. Technology Selection

Technology choices were guided by three criteria: open-source availability, proven track record in production environments, and reasonable operational complexity. The following table summarizes the chosen technologies and the reasoning behind each pick.

| Component      | Chosen Tool        | Alternative | Why                                                            |
|----------------|--------------------|-------------|----------------------------------------------------------------|
| Encryption     | GPG / PGP          | S/MIME      | Open-source, free, no certificate authority needed             |
| Email Client   | Thunderbird        | Outlook     | Built-in OpenPGP, cross-platform, free                         |
| Spam Filter    | SpamAssassin       | Mimecast    | Open-source, mature, widely deployed                           |
| Antivirus      | ClamAV             | Sophos      | Free, integrates with mail pipelines                           |
| DNS Server     | BIND9              | Windows DNS | Standard, full TXT record support                              |
| Authentication | SPF + DKIM + DMARC | SPF only    | Layered approach catches more spoofing                         |
| DLP            | Custom Python      | Forcepoint  | Easily customisable for India-specific patterns (PAN, Aadhaar) |

## 5. Integration Plan

Integration follows a defense-in-depth path. The flow below shows how an inbound and outbound message would travel through the proposed architecture:

### 5.1 Inbound Mail Flow

Internet -> Edge Firewall -> Secure Email Gateway -> ClamAV scan -> SpamAssassin score -> SPF/DKIM/DMARC verification -> Mail Server -> User Mailbox (decrypted locally if PGP)

### 5.2 Outbound Mail Flow

User composes mail in Thunderbird -> Optional PGP encryption + digital signature -> Mail Server -> DLP Engine inspects content -> SPF/DKIM signing -> Internet -> Recipient

### 5.3 Deployment Phases

To keep risk low, deployment is recommended in three phases:

- Phase 1 ( 1-2 Days): DNS authentication - publish SPF, DKIM, DMARC records in monitor-only mode
- Phase 2 (3-4 Days): Gateway deployment - bring SpamAssassin and ClamAV inline, tune false-positive rates
- Phase 3 (4- 9 Days) : Encryption rollout - issue PGP keys to technical staff first, then expand to all departments

## 6. Conclusion

The architecture proposed in this document brings the consulting firm's email environment in line with current best practices for confidentiality, integrity, and authentication. Each layer was selected for operational practicality and verified during the practical phase on Kali Linux.

The remaining deliverables in this submission document the specific implementation details for encryption, digital signatures, gateway configuration, user training, and the supporting policy framework. Read together, they form a complete blueprint that the consulting firm's IT team can use to migrate from the current insecure baseline to a hardened email environment without commercial licensing costs.